

Overview of Cybersecurity



Nancy LaTourrette
Computer Science & Engineering

Anonymity



when Internet started out,
and still generally true

by Peter Steiner,
New York, July 5, 1993

Significant Events

1957: Sight impaired seven-year old, Joe Engressia “Joybubbles”, discovered a whistling tone that reset trunk lines resulting in free phone calls.

1971: John Draper, “Captain Crunch”, ^{→ whistle from the cereal box!} built Bluebox to replicate phone tones resulting in free long distance. “If I do what I do, it is only to explore a system”.

1988: Robert Morris developed a worm which brought down a large part of the Internet, ~ 6,000 computers.

1995: Kevin Mitnick ^{→ article, “gray hat”?} became first hacker on FBI’s Most Wanted List. ^{4BSD on DEC VAX/Sum-3} Stole 20,000 credit card numbers. Used social engineering as primary source to gain access.

Growth of the Internet

1960s: Research into robust, fault-tolerant communication via computer networks.

1970s: ARPNET connected research universities. Expanded in the 1980s. Electronic mail (email) developed.

1980s: Rapidly increasing growth in desktops and personal computers.

1990s: Explosive growth in the internet. Moved from research focus to general public. Start of commercial Internet Service Providers (ISPs).

Cybersecurity

"The ability to protect or defend the use of cyberspace from cyber attacks."

-- National Institute for Standards and Technology (NIST)

"A comprehensive cybersecurity program leverages industry standards and best practices to protect systems and detect potential problems, along with processes to be informed of current threats and enable timely response and recovery." ↳ NIST Cyber Security Framework
PCIDSS
ISO 27001

-- Department of Homeland Security

CIA Triad

Three basic security concepts important to information (data) are confidentiality, integrity, and availability.

Confidentiality: Protecting information from disclosure to unauthorized parties. → strong passwords / 2FA, etc.

Integrity: Information is ensured to not have been corrupted or modified in unexpected ways. record-keeping
appropriate user permissions

Availability: Ensuring that authorized parties are able to access the information when needed. robust disaster recovery
backup system
resilient infrastructure

User Security Concepts

Concepts relating to the user (person, application, or system) of information are authentication, authorization, and nonrepudiation.

Authentication: Proving that the credentials provided are those of the authorized user.

Authorization: Determining whether a user has the right to access specific data or execute an activity.

Nonrepudiation: Associating actions or changes to a unique individual. Means of authentication cannot later be refuted.

Threat Types & Motivations

Three areas of threats countered by cybersecurity can be characterized as cybercrime, cyberwarfare, and cyberterrorism.

Cybercrime: Single actors or groups targeting systems for financial gain. *e.g. identity theft, ransomware*

Cyberwarfare: Involves information gathering and is politically motivated. *on the level of state actors. Stuxnet-Iran. NK/Russia WannaCry ransomware*

Cyberterrorism: Intended to undermine systems and cause panic or fear. *DDoSing government websites*

Types of Cybercrime

Intrusions: Gaining unauthorized access to a system (computer or network).

Ransomware: Malware encrypts files and demands a ransom for the key to decrypt.

Espionage: Covertly observing or destroying data of governments or large enterprises.

Intellectual Property (IP): Theft of copyrighted material, trade secrets, and trade mark violations.

Fraud/Financial: Tricking victims out of money, property or inheritance.

Intruder Actions

Intruder actions and the consequences to the CIA Triad and User Security.

Eavesdrop: Intercept messages.

Insertion: Insert messages into the connection.

Impersonation: Fakes (spoofs) source address or other field in packet or fakes an identity.

Hijacking: “Take over” a session by removing sender or receiver and inserting him/her self instead.

Denial of Service: Prevents services from being used by others by overloading systems.

Cyberspace Abuses

There are other abuses of cyberspace in addition to cybercrime rooted in financial and espionage.

Cyberstalking: Harassing or threatening a person or group by electronic means.

Cyberbullying: Sharing private information with the intent to cause embarrassment or humiliation. Usually over email, texts, social media or instant messages.

Sexual Exploitation: Manipulating a person into doing something sexual such as sending sexual photos of themselves online.

Cyberspace Abuses

Identity Theft: Stealing a person's personal information to commit fraud. Not just financial: Can also include social security numbers, driving records and medical records, etc.

Cyber Assisted Crimes: Basic crimes that are made easier by using "cybertechnology" such as tax fraud or industrial espionage.

Definitions

Attacker, Hacker, Intruder: Persons who seek to exploit weaknesses in software and computer systems for their own gain.

Malicious Code: Malicious code includes any code that could be used to attack a system.

Vulnerability: In most cases, vulnerabilities are caused by programming errors in software. Attackers may exploit errors to infect your computer.

Definitions

Data breach: *The unauthorized movement or disclosure of sensitive information to unauthorized persons.*

Security Event: An event on a system or network detected by a security device or application.

Attack: A security event identified as malicious activity that is attempting to collect, disrupt, deny, degrade or destroy data and/or systems.

Security Incident: An attack or security event that has been reviewed by an organization's security team and deemed worthy of deeper investigation.